Pr Out STUDIO

プロトタイピングで
ガンガン作って攻めるための、
最低限の身の丈セキュリティ話

第2回 ものづくり医療研究会

2026/11/15（日）13:45〜 ふれあい貸し会議室 秋葉原No53



菅原のびすけ

- プロトタイピングスクール「プロトアウトスタジオ」
- デジタルハリウッド大学大学院 非常勤講師
  - プロダクトプロトタイピング

個人活動

- IoTLT（国内最大のIoTコミュニティ）主催
- Developers Summit 2025 ベストスピーカー 1位
- LINE API Expert / Microsoft MVP / IBM Champion

産院の院長がChatGPTで患者呼び出しシステムを作った



産院のいんちょ (@A_Mochizuki) on X

X (formerly Twitter) / 2026-10-16

Pythonは書けないけど、院内LANから呼べる待合室の呼び出しシステム（@A_Mochizuki さん 2026/10/16）

今日のメッセージ

セキュリティが心配だから作らない、ではなく

「ここは意識してます」と自信を持って言えるから、
ガンガン作れる

集めない

持っていない情報は漏らせない

予約の時点で、生年月日まで聞かれる



以下の必要項目に入力をお願いします

診療されるご本人のお名前

姓 *
例) 山田

名 *
例) 太郎

セイ *
例) ヤマダ
カナまたはアルファベット

メイ *
例) タロウ
カナまたはアルファベット

生年月日 *
年 月 日

性別 *
男性 女性

電話番号 *
ハイフンなしで入力

メールアドレス *
予約の完了メールなどを受信します
メールアドレスを持っていない
メールアドレスは必須です

郵便番号 *
例) 1234567

住所 *
日本語

ある医療機関のWeb予約フォーム（必須：氏名・フリガナ・生年月日・性別・電話番号・メール・郵便番号・住所）

来院したら、問診票でもまた生年月日を書く

紙の問診票でも、生年月日とか無駄に聞くのはやめよう

- アプリでも紙でも、書いてもらった情報は持つことになる
- 紙もなくす、置き忘れる、見られる
- => 紙の問診票からも、要らない項目を消す

修学旅行で名簿の入ったリュックを紛失



修学旅行中に教員がリュックサックを紛失　2年生226人全員の個人情報流出の可能性　広島県立の高校で（RCC中国放送） - Yahoo!ニュース

Yahoo!ニュース

持たない

毎回生年月日を入れさせたくない

でも、**DBには貯めたくない**

病院の個人PCでサポート詐欺

2026 06/03 wed お知らせ

個人情報漏洩に関するご報告とお詫び

令和8年6月3日

患者様各位

藤田医科大学病院
病院長　今泉 和良

愛知県の藤田医科大学病院で個人情報漏えいの可能性、規定に反して情報を持ち出した個人PCがサポート詐欺に

INTERNET Watch / 2026-06-05



サポート詐欺で発覚 ～ 産婦人科医師が不適切な状態で患者データ保管 | ScanNetSecurity

ScanNetSecurity

2回目からはパスキーでログイン

- パスワードを作らせない
- 使い回しを防ぎやすい
- フィッシングに強い
- パスワード再設定を作らなくていい

参考: Setlogの登録画面

患者DB・問診DB・対応表を分ける

患者DB

- 患者ID
- 氏名
- 生年月日

漏れても問診内容は出ない

問診DB

- 問診ID
- 症状、既往歴
- 暗号化

漏れても氏名は出ない

対応表

- 患者IDと問診IDの対応だけ
- 別の場所に置く

見られる人を絞る

IDを分けただけでは匿名化にはならない

DBだけじゃなく、サーバーや場所、ネットワークも分けておく

- 1. 同じDBの中でテーブルを分ける
- 2. 別のDBに分ける
- 3. 別のサーバーに分ける
- 4. 別のネットワーク・クラウド環境に分ける
- 5. アカウント・アクセス権限を分ける
- 6. 暗号鍵の管理も分ける

分けすぎると運用が大変になるので、身の丈で

集めない・持たない・分ける

漏れても被害が小さくなる設計

「URLを知ってる人だけ」はアクセス制御じゃない

- robots.txt => セキュリティの仕組みじゃない
- noindex => 検索に出にくくするだけ
- => 見せたくないデータには**認証とアクセス制御**

例: ChatGPT の共有リンクの会話が、検索結果に出ていた（2025年8月）

学習に使われない ≠ ログが残らない

- ChatGPT Business / Enterprise => 原則、業務データを学習に使わない
- OpenAI API => デフォルトで学習に使わない
- Gemini API => 有料扱いかどうかで条件が変わる
- 試作は**ダミーデータ**で

規約は変わるので、使う前に公式のページで確認する

まとめ

- 動くアプリと安全なアプリは違う
- **集めない・持たない・分ける**で、漏れても被害が小さい設計に
- 限定公開URLはアクセス制御じゃない

=> 「そもそも集めてない」「分けてある」と自信を持って言えるようにして、ガンガン作ろう